

ACTIVIDAD 05

Cartografiando el pentesting: análisis comparativo
de metodologías de seguridad informática

Gustavo Michael Larios Guerra - 178318



Metodología	Descripción	Objetivo principal	Escenarios	Orientación	Autores	URL del material	certificaciones	Versiones
MTRE ATT&CK	Es un conjunto de tácticas para prevenir y combatir las amenazas de ciberseguridad basadas en las acciones de los delincuentes cibernéticos.	crear políticas y controles de seguridad y planes de respuestas a incidentes más eficaces.	Clasificación de alertas y detección de amenazas. Emulación de adversarios. Análisis de brechas de seguridad.	Defensa y evaluación de seguridad.	MITRE Corporation.	MITRE .	CDE (Certified Defender)	v18.1 (25 oct 2025) v17.1 (22 abr 2025) v16.1 (31 oct 2024) v15.1 (23 abr 2024) Entre más versiones.
OWASP WSTG	Es una prueba para probar la seguridad de aplicaciones y servicios web,	Preparación, pruebas de configuración, identidad.	Evaluación técnica de vulnerabilidades.	Evaluación.	Fundación OWASP.	OWASP .	No existe certificación.	5.0 (versión actual en desarrollo). 42 (4.2)
NIST SP 800-115	Ayudar a las organizaciones a planificar y realizar pruebas y exámenes técnicos de seguridad de la información.	Analizar hallazgos y desarrollo de estrategias de mitigación. Planificación, ejecución y post-ejecución.	Pruebas de penetración. Evaluación de riesgos.	Evaluación.	Karen Scarfone (NIST), Murugiah Spupaya (NIST), Amanda Cody (BAH), Ángela Orebaugh (BAH)	NIST .	No existe certificación.	SP800-115 (30 ago 2008)
OSSTMM	Es un estándar internacional para la realización de pruebas de seguridad de diversos temas como redes y aplicaciones web entre otros.	Proporcionar un marco de trabajo que describa las fases a seguir en la ejecución de una auditoría de seguridad o Pentesting. Inducción, logística y análisis.	Medición del nivel de seguridad (Blindside).	Evaluación (auditorías).	Instituto para la seguridad y metodologías abiertas (ISECOM)	https://www.isecom.org/OSSTM.M.3.pdf (manual) ISECOM .	OPSA (OSSTMM Professional Security Analyst). OPST (OSSTMM Professional Security Tester). proporcionadas por ISECOM que validan los conocimientos en OSSTMM.	v3.0 Versión actual.
PTES	Consta de siete secciones principales que cubren todo	Interacciones previas al compromiso. Recopilación de	Normalización del flujo de trabajo de	Evaluación (auditorías).	OISSG.	PTES .	No existe certificación.	v2.0 (versión en desarrollo) v1.0

	acerca de pruebas de penetración, pasando por las fases de recopilación de inteligencia y modelado de amenazas.	inteligencia. Modelado de amenazas. Análisis de vulnerabilidades. explotación. Post-Explotación . Informes.	un Pentest.					
ISSAF	Es un marco integral diseñado para garantizar que las pruebas de penetración y evaluaciones de seguridad sean eficientes y aborden todos los aspectos críticos de la infraestructura tecnológica.	* Planificación: definir el alcance, los objetivos y las reglas de la evaluación. * Reconocimiento: obtener información pasiva y activa sobre los sistemas objetivo. * Mapeo de infraestructura y análisis. * Evaluación de vulnerabilidades: Identificar vulnerabilidades conocidas en los sistemas y aplicaciones * Explotación (ataque): Validar vulnerabilidades detectadas explotándolas de forma controlada. * Análisis y mitigación de vulnerabilidades: proponer soluciones para corregir las vulnerabilidades explotadas y mejorar la seguridad del sistema. * Informe Final y presentación: Documentar todos los hallazgos, el impacto de las vulnerabilidades explotadas y las recomendaciones para mitigarlas.	Evaluación de seguridad alineada a los objetivos del negocio.	Evaluación (auditoría)	OISSG	ISSAE	No existe certificación.	v.02

